

Information Security Policy

Document ID: POL-SEC-000 (master policy) **Owner:** Jonas Weber, Head of Security **Approved by:** Maya Okafor, CEO **Version:** 5.1, effective 1 February 2026 **Review cycle:** annual, next review January 2027

1. Purpose and scope

This policy defines the security controls that protect Northwind Labs, our employees and the customer data processed by Atlas and Beacon. It applies to every employee, contractor and intern, to every device that accesses Northwind systems and to every third party that handles Northwind data.

Each control has a stable identifier in the form POL-SEC-NNN. Identifiers are never reused, so a control that is retired keeps its number. When you report an exception or answer an audit question, always quote the control identifier.

2. Roles

- **Head of Security (Jonas Weber)** owns this policy, approves exceptions and reports security risk to the leadership team every quarter.
- **IT Operations** manages Okta, Google Workspace, laptops and mobile device management (Kandji for macOS, Intune for Windows).
- **Managers** make sure their teams complete security training and that access is removed when people change roles.
- **Every employee** follows the controls below and reports suspected incidents immediately.

3. Control index

Control	Topic
POL-SEC-003	Acceptable use (see the Acceptable Use Policy)
POL-SEC-009	Data classification
POL-SEC-011	Access provisioning and reviews
POL-SEC-014	Passwords and multi-factor authentication
POL-SEC-017	Privileged access
POL-SEC-021	Endpoint security and screen lock
POL-SEC-026	Removable media and file sharing
POL-SEC-030	Security incident reporting
POL-SEC-033	Security awareness training
POL-SEC-037	Third-party and vendor access
POL-SEC-041	Clean desk and physical security

4. Data classification (POL-SEC-009)

All information is classified into one of four levels. The owner of a document or dataset sets the label; if in doubt, choose the higher level.

Level	Examples	Handling
Public	Marketing site, published blog posts, public docs	No restrictions
Internal	Handbook, company policies, all-hands slides	Share only with Northwind employees and contractors
Confidential	Customer contracts, roadmaps, source code	Need-to-know; never in personal accounts
Restricted	Customer data in Atlas, payroll, health information	Encrypted at rest and in transit; access logged and reviewed quarterly

Restricted data must never be pasted into public AI tools, personal email, or unapproved SaaS applications.

5. Access provisioning and reviews (POL-SEC-011)

Access is granted through Okta groups based on role. Requests for additional access go through the #it-help Slack channel using the "Access request" workflow and need approval from the system owner. Managers review their team's access every quarter; access not confirmed within 10 business days of the review is removed automatically.

When an employee leaves, Okta access is disabled no later than the end of their last working day.

6. Passwords and multi-factor authentication (POL-SEC-014)

POL-SEC-014 sets the rules for every account that can reach Northwind data:

1. Passwords must be at least **14 characters** long. Passphrases of four or more random words are recommended.
2. Passwords must be unique: never reuse a Northwind password on any other site.
3. All passwords are stored in the company 1Password vault. Browser password storage is not allowed for work accounts.
4. Passwords are not rotated on a schedule; they must be changed immediately if a compromise is suspected.
5. **Multi-factor authentication is mandatory** on Okta and on every application that supports it. The approved factor is Okta Verify with push and number matching. SMS codes are not allowed as a second factor.
6. Accounts with administrative privileges must use a password of at least **20 characters** and a **hardware security key (YubiKey 5 series)** as the second factor.
7. After 10 failed login attempts an Okta account is locked for 30 minutes.

Never share an MFA approval: if you receive a push prompt you did not trigger, deny it and report it in #security-help.

7. Privileged access (POL-SEC-017)

Administrative access to production systems, Google Workspace, Okta and finance systems is granted just-in-time for a maximum of 8 hours and is logged. Standing admin rights are limited to named owners listed in the access register maintained by IT Operations. Privileged sessions must be started from a managed Northwind laptop.

8. Endpoint security and screen lock (POL-SEC-021)

- Only Northwind-managed laptops may access Confidential or Restricted data.
- Full-disk encryption (FileVault or BitLocker) must be enabled; IT enforces this through device management.
- The screen must lock automatically after **5 minutes** of inactivity. Lock your screen manually (Ctrl+Cmd+Q on macOS, Win+L on Windows) whenever you step away.
- Operating system updates must be installed within 14 days of release, and critical security updates within 72 hours.
- The endpoint protection agent (CrowdStrike Falcon) must not be disabled or uninstalled.

9. Removable media and file sharing (POL-SEC-026)

USB storage devices are blocked by default on managed laptops. Files are shared through Google Drive with sharing restricted to the northwind.example domain. External sharing of Confidential documents requires a link with an expiry date of no more than 30 days.

10. Security incident reporting (POL-SEC-030)

Report any suspected security incident, such as a lost laptop, a phishing email you clicked, or data sent to the wrong person, **within 1 hour** of noticing it:

- Slack: #security-help (monitored around the clock)
- Email: security@northwind.example
- Phone (outside office hours): +351 21 000 4400

Do not try to investigate on your own and do not delete evidence. Use the "Report phishing" button in Gmail for suspicious emails. Reporting a mistake quickly is never punished; hiding one may be.

11. Security awareness training (POL-SEC-033)

New joiners complete the Northwind Security Basics course in their first week. All employees complete the annual refresher by 31 March each year and take part in quarterly phishing simulations. Engineers complete an additional secure-coding module.

12. Third-party and vendor access (POL-SEC-037)

Before a new vendor receives Confidential or Restricted data, the Security team completes a vendor risk assessment. Vendors with access to Restricted data must hold a current SOC 2 Type II report or ISO 27001 certification. Vendor accounts are reviewed every 6 months and expire automatically after 12 months unless renewed.

13. Clean desk and physical security (POL-SEC-041)

Wear your Northwind badge visibly in all offices. Do not let people tailgate through badge-controlled doors. Lock away printed Confidential documents at the end of the day and use the locked shredding bins for disposal. Visitors must be registered in advance and accompanied at all times (see the Guest Wi-Fi and Visitors page in the handbook).

14. Exceptions

Exceptions to any control must be requested through the "Security exception" form in Jira Service Management, must name the control identifier (for example POL-SEC-021) and must be approved by the Head of Security. Exceptions are granted for a maximum of 90 days and are tracked in the exception register.

15. Enforcement

Violations of this policy may lead to removal of access and to disciplinary action up to and including termination of employment or contract. Deliberate attempts to bypass a security control are always treated as serious misconduct.

16. Related documents

- Acceptable Use Policy (POL-SEC-003)
- IT Setup Guide (handbook)
- Equipment Return Process (handbook)